PROJECT DEFINITION

Enterprise Threat Hunting & Detection Using Splunk SIEM

Author	Krishna Patel
Platform	Splunk Enterprise | Sysmon | Windows 11 VM | Kali Linux | MacOS (UTM / ARM64)
Framework	MITRE ATT&CK v14
Detection Rules	T1110.001 | T1110 | T1059.001 | T1136.001 | T1110 + T1059.001 + T1136.001 (Multi-Stage Chain)

There are multiple detection rules implemented within the Splunk SIEM environment to enhance security monitoring and strengthen visibility across the network. This document outlines one complete project lifecycle focused on authentication monitoring, PowerShell execution detection, and privileged account creation within a simulated enterprise lab environment.

Security Objective: Detect and respond to brute-force login attempts, account compromise, suspicious PowerShell execution, and unauthorized admin account creation in a controlled lab environment, leveraging Splunk SIEM, Sysmon telemetry, and threat intelligence mapped to the MITRE ATT&CK framework.

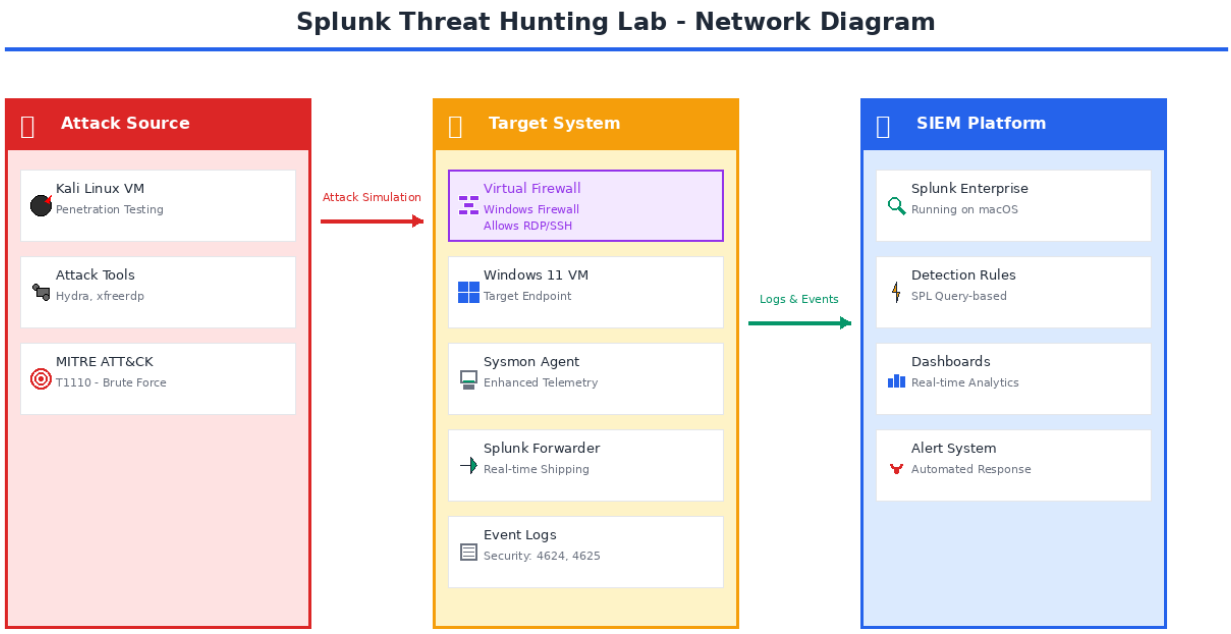

Figure 1: Lab architecture - Attack Source (Kali Linux VM), Target System (Windows 11 VM), SIEM Platform (Splunk Enterprise on macOS)

Stage 1: Define Security Objective

The key objective of this project is to build a detection engineering capability within a simulated enterprise environment using Splunk SIEM. Threat hunting hypotheses were defined and mapped to the MITRE ATT&CK framework, guiding the creation of four targeted detection rules. The lab simulates realistic attacker behavior using Kali Linux against a Windows 11 ARM64 virtual machine, with Sysmon providing enhanced endpoint telemetry and the Splunk Universal Forwarder shipping logs in real time to Splunk Enterprise on a macOS host.

Scope: Windows 11 ARM64 VM (log source and attack target), Kali Linux VM (attack simulation), Splunk Enterprise SIEM on macOS host, Sysmon for Windows telemetry, dashboard creation and real-time alerting.

Detection Objectives

- Detect multiple failed login attempts indicative of brute-force activity (T1110.001)
- Detect successful authentication following repeated failures, signaling credential compromise (T1110)
- Monitor for suspicious PowerShell invocations using encoded commands to evade detection (T1059.001)
- Alert on creation of new privileged accounts outside of approved change windows (T1136.001)
- Correlate multi-stage attack chains spanning brute force, execution, and persistence stages

Threat Hunting Hypotheses

Effective threat hunting begins with a hypothesis. Each scenario below drives the detection logic built in Stage 3:

#	Hypothesis	Expected Observable	ATT&CK Tactic
H1	Attacker is brute-forcing RDP credentials against the Windows VM	10+ Event ID 4625 from same source IP within 5 minutes	Credential Access (T1110.001)
H2	Compromised account logs in after repeated authentication failures	Event ID 4624 preceded by 5+ Event ID 4625 for same account	Initial Access (T1110)
H3	Attacker executes encoded PowerShell to evade endpoint defenses	Sysmon Event ID 1 with -EncodedCommand flag in CommandLine	Execution (T1059.001)
H4	New privileged account created outside approved change windows	Event ID 4720 + 4732 for new account added to Administrators group	Persistence (T1136.001)
H5	Full attack chain from initial access through persistence is underway	3+ attack stages correlated across brute force, execution, persistence	Multi-stage (T1110+T1059+T1136)

Expected Outcomes: Real-time Splunk alerts triggered by simulated attack activity, SOC-ready dashboards displaying authentication and execution anomalies, SPL detection logic documented and mapped to ATT&CK techniques, and a validated incident response workflow for each detection scenario.

Stage 2: Risk Assessment

A structured risk assessment was conducted to identify assets, define threat scenarios, evaluate probability and impact, and prioritize mitigation efforts within the simulated enterprise environment.

Asset Identification

The following critical assets were identified within the simulated environment:

- Windows 11 ARM64 Virtual Machine - primary target endpoint and log source (192.168.64.10)
- Kali Linux Virtual Machine - designated attack platform (192.168.64.2)
- Splunk Enterprise - SIEM platform on macOS host (172.16.37.32:8000), 500MB/day free trial
- Sysmon64a - ARM64 endpoint telemetry agent capturing process, network, and registry events
- Splunk Universal Forwarder - log shipping agent on Windows VM, forwarding to Splunk on port 9997
- User and administrator accounts on the Windows VM - subject to brute-force and account creation attacks

Threat Identification

Potential threats were identified based on the simulated attack scenarios and mapped to the MITRE ATT&CK framework:

- **Brute-Force Attacks (T1110.001):** Repeated failed RDP authentication attempts from the Kali Linux VM targeting the Windows administrator account.
- **Credential Compromise (T1110):** Successful login following a burst of failed authentication attempts, indicating a stolen or guessed password.
- **Suspicious PowerShell Execution (T1059.001):** Use of Base64-encoded PowerShell command-line arguments and evasion flags to execute payloads while avoiding detection.
- **Unauthorized Admin Account Creation (T1136.001):** Creation of new local user accounts with elevated privileges, a common persistence technique following initial access.

Vulnerability Assessment

- **No account lockout policy:** Intentionally disabled on the Windows VM to enable brute-force simulation without interruption.
- **No Multi-Factor Authentication:** MFA not configured on simulated accounts, increasing exposure to credential-based attacks.
- **Flat network topology:** No segmentation between the Windows VM and Kali Linux VM within the UTM virtual network.
- **Default audit policies insufficient:** Windows native logging does not capture process-level detail - Sysmon is essential for Rules 3, 4, and 5.

Risk Analysis and Evaluation

Risk	ATT&CK ID	Probability	Impact	Severity
Brute-force RDP attack	T1110.001	High	High	Critical
Credential compromise	T1110	Medium	High	High
Encoded PowerShell execution	T1059.001	Medium	High	High
New admin account creation	T1136.001	Low	High	Medium

Cost-Benefit Analysis: Resource investment included two UTM virtual machines on Apple Silicon Mac, Splunk Enterprise free trial, Sysmon64a with SwiftOnSecurity config, and the Splunk Universal Forwarder. The benefit realized includes detection coverage across four ATT&CK techniques, a functioning SOC dashboard, and a reusable detection engineering framework.

Residual Risk: Threshold-based rules may miss low-and-slow brute-force attacks that stay below the 10-attempt threshold. PowerShell payloads that avoid the -EncodedCommand flag would not be captured by Rule 3 in its current form. Multi-stage chain detection requires all stages to involve the same Account_Name, which may not apply in all real-world scenarios. These gaps are documented in Stage 5 for future remediation.

Stage 3: Implement Security Controls

The following procedure was followed to implement the detection engineering controls within the Splunk SIEM environment. All configurations were validated by confirming that events flowed correctly into Splunk before proceeding to detection rule creation.

Lab Setup and Configuration

- **Sysmon Installation (ARM64):** Installed Sysmon64a.exe, the ARM64-specific binary using the SwiftOnSecurity configuration file. The standard Sysmon64.exe fails on Apple Silicon VMs with errorCode=5 due to driver signing restrictions. Sysmon64a captures Event IDs 1 (Process Creation), 3 (Network Connection), 11 (File Creation), and 13 (Registry Value Set).
- **Windows Audit Policies:** Enabled via gpedit.msc for Logon events (4624, 4625), Account Lockout (4740), User Account Management (4720, 4732), and Process Creation (4688). Verified using auditpol /get /subcategory commands.
- **Splunk Universal Forwarder:** Installed on the Windows VM and configured via inputs.conf to monitor the Security log channel, System log channel, and Microsoft-Windows-Sysmon/Operational channel with renderXml=true. Forwarder set to run as Local System account to resolve Sysmon channel permission errors.
- **Splunk Indexes:** Created two indexes in Splunk Enterprise: wineventlog for Windows Security and System logs, and sysmon for Sysmon XML events. Receiving port 9997 configured in Splunk Settings.

Detection Rule Implementation

Four SPL-based detection rules were created and saved as real-time alerts in Splunk. Each rule is mapped to a MITRE ATT&CK technique and configured with a Per-Result trigger that adds fired events to the Triggered Alerts queue for SOC review.

Rule 1: Brute Force Login Detection (T1110.001): Detects 10 or more failed login attempts from the same source IP within a 5-minute window. Uses Event ID 4625 from the wineventlog index, grouped by time bucket, account name, and Source_Network_Address. Note: the correct field name in Windows Event Log is Source_Network_Address, not src_ip.

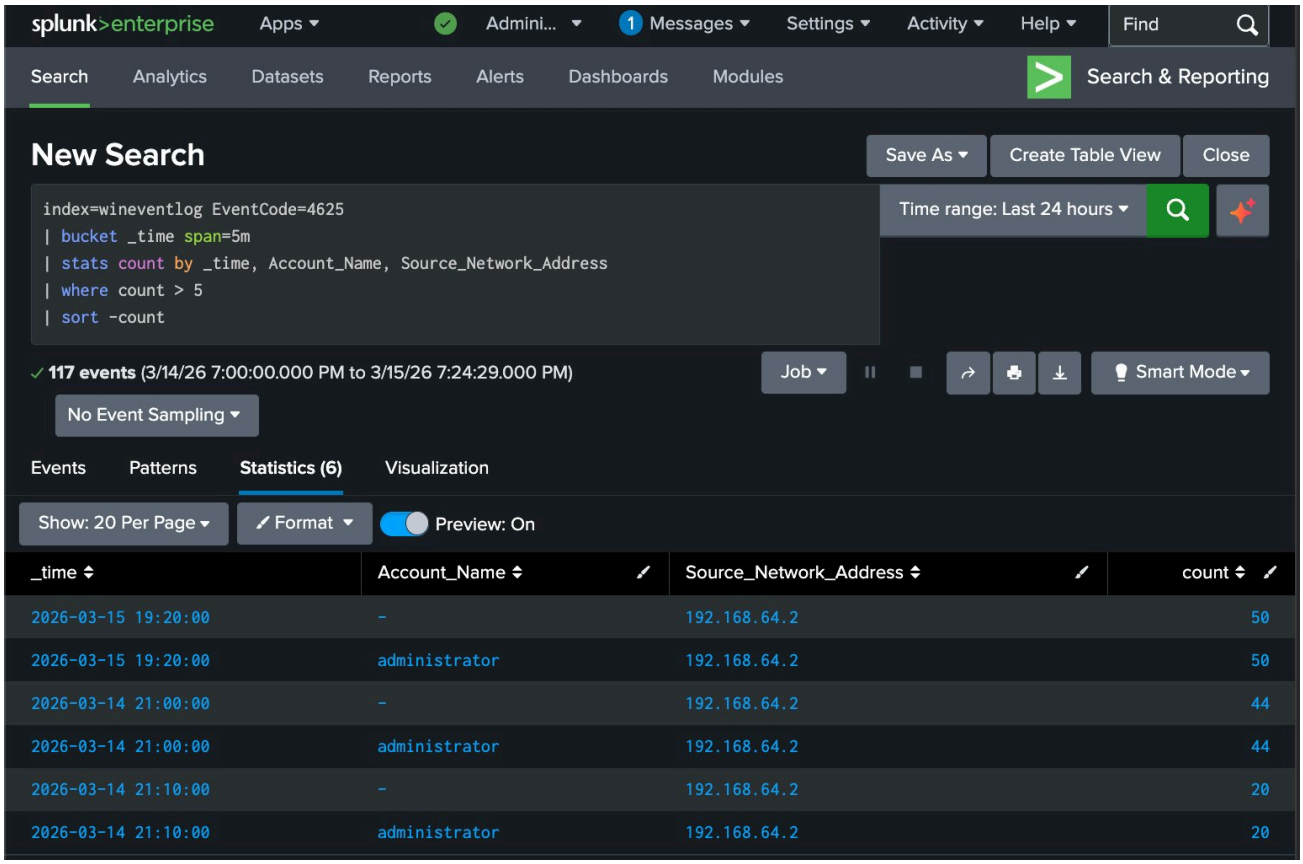

Figure 2: Rule 1 - 50+ failed logins from 192.168.64.2 (Kali Linux) detected in a 5-minute bucket

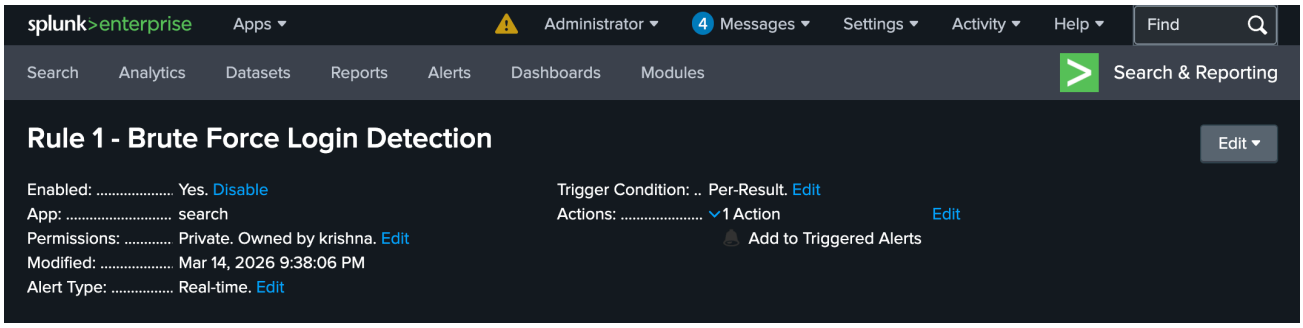

Figure 3: Rule 1 saved as a Real-time Per-Result Splunk Alert

Rule 2: Successful Login After Failures (T1110): Detects credential compromise by identifying accounts with 5 or more failed logins followed by at least one successful login from the same source IP. Correlates Event ID 4625 (failure) and 4624 (success) using eval and stats commands.

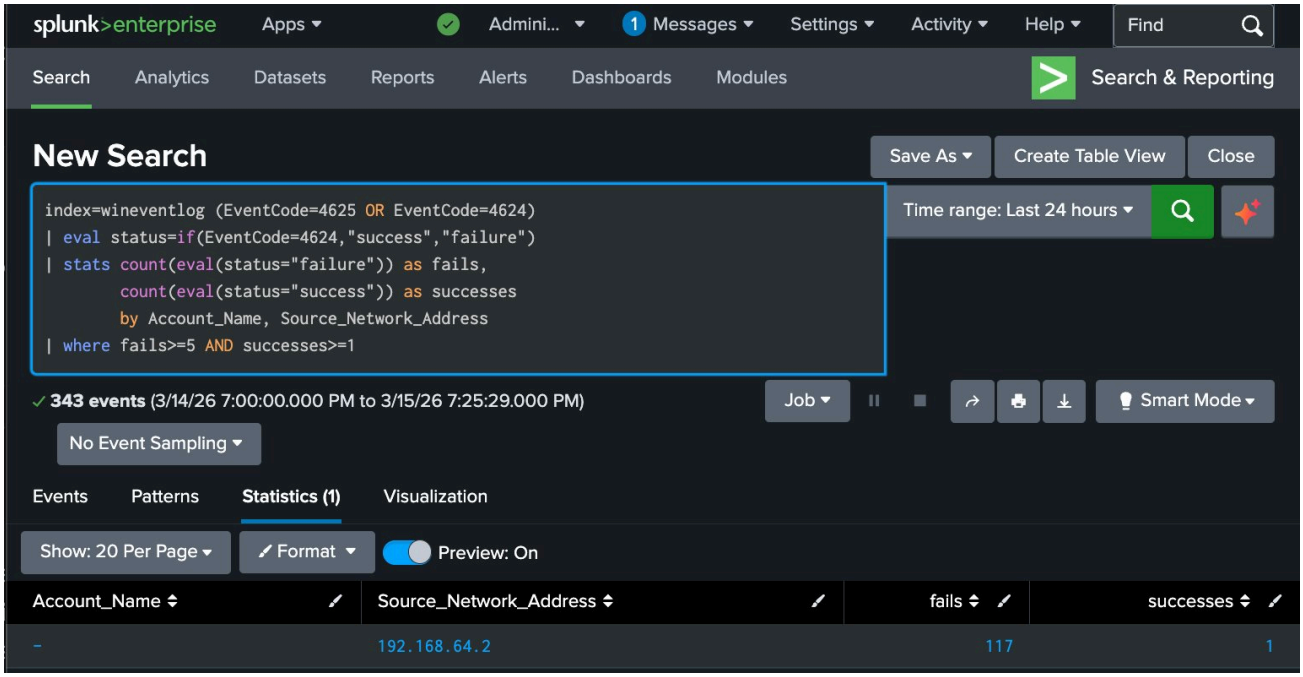

Figure 4: Rule 2 - 117 failures followed by 1 successful login from Kali IP detected

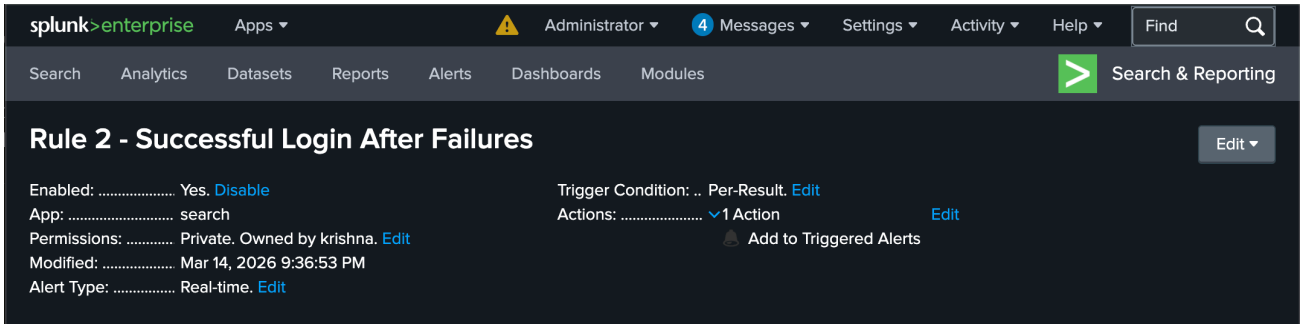

Figure 5: Rule 2 saved as a Real-time Splunk Alert

Rule 3: Suspicious Encoded PowerShell (T1059.001): Detects encoded or obfuscated PowerShell execution via Sysmon Event ID 1. Because Sysmon logs are stored in the XmlWinEventLog sourcetype in Splunk, standard field names are not auto-extracted. Rex commands parse the Image and CommandLine fields directly from raw XML to identify the -EncodedCommand flag.

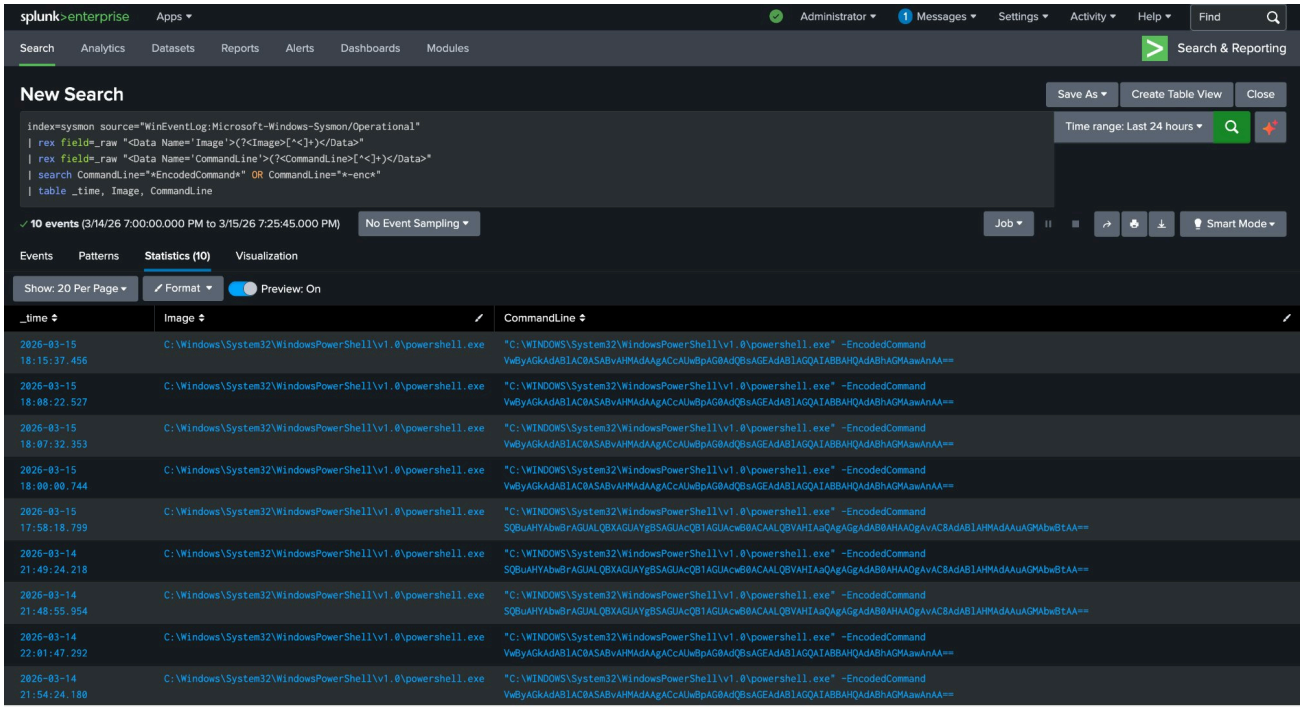

Figure 6: Rule 3 - 10 encoded PowerShell executions detected via Sysmon with full CommandLine captured

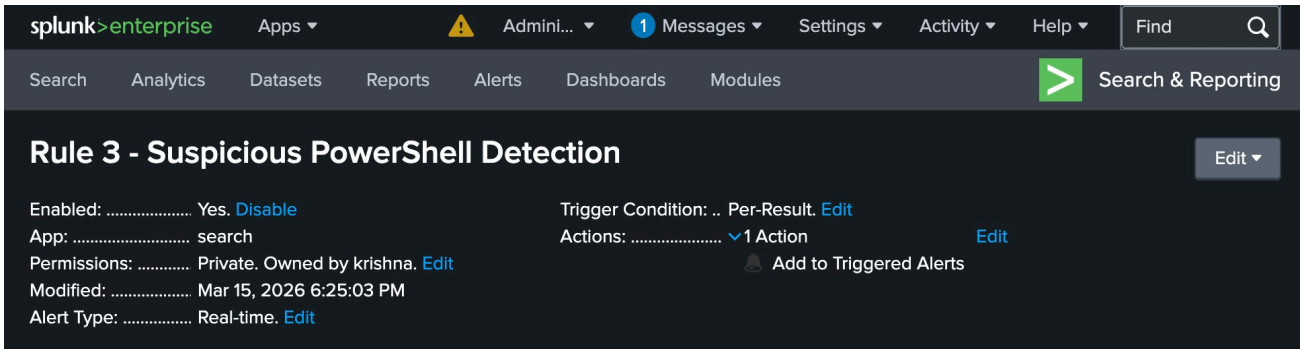

Figure 7: Rule 3 saved as a Real-time Splunk Alert

Rule 4: New Admin Account Creation (T1136.001): Detects the creation of a new local user account and its immediate addition to the Administrators group using Event ID 4720 (account created) and Event ID 4732 (member added to security-enabled local group). SubjectUserName field identifies the account that executed the commands.

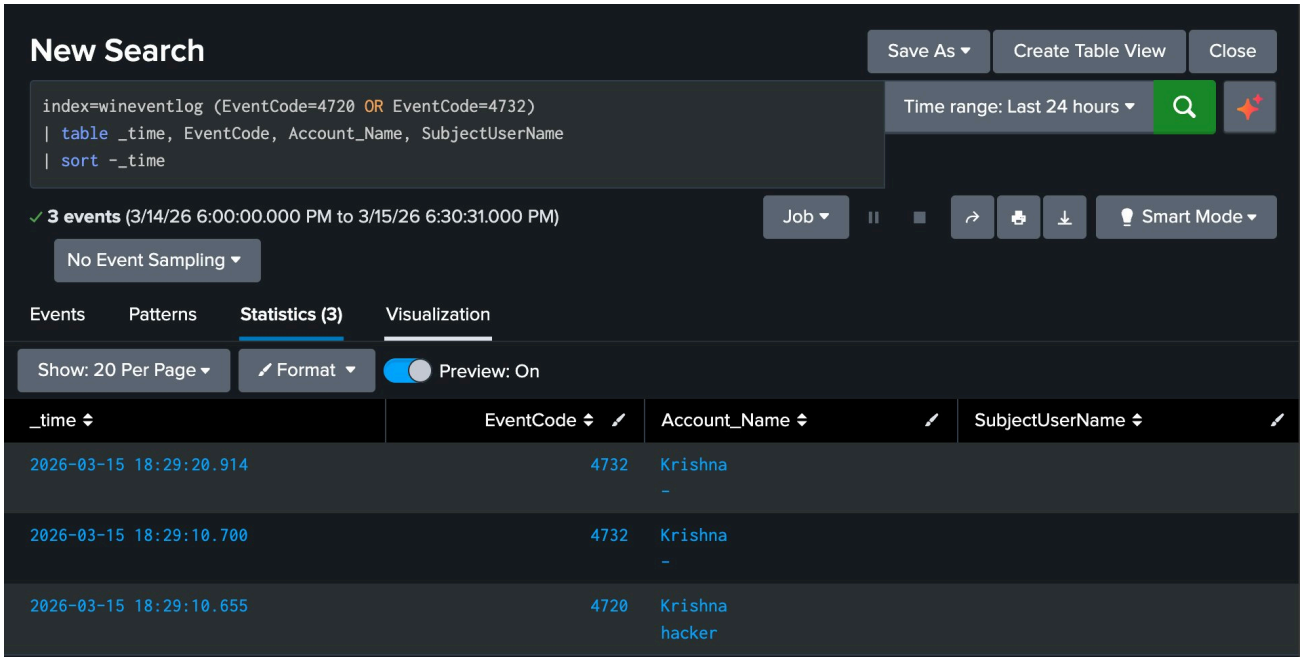

Figure 8: Rule 4 - Event 4720 (user hacker created) and Event 4732 (added to Administrators) detected within seconds

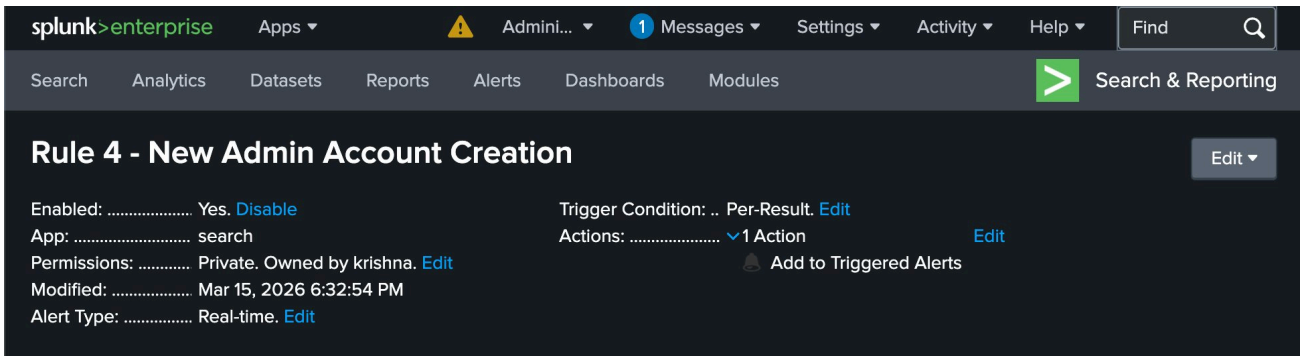

Figure 9: Rule 4 saved as a Real-time Splunk Alert

Rule 5: Multi-Stage Attack Chain Detection (T1110 + T1059.001 + T1136.001): This is the most advanced detection rule in the project — a multi-stage correlation rule that identifies accounts involved in 3 or more phases of a complete attack chain. The rule uses Splunk's append command to merge events across three separate indexes and data types: brute-force failures and successful access from the wineventlog index, encoded PowerShell execution from the sysmon index, and persistence via account creation from the wineventlog index. It then correlates these events by Account_Name and uses mvcount to identify accounts that appear in at least 3 attack stages, producing a clear attack chain visualization such as 1_BruteForce → 2_InitialAccess → 4_Persistence. This rule demonstrates end-to-end attacker activity mapped to the MITRE ATT&CK kill chain.

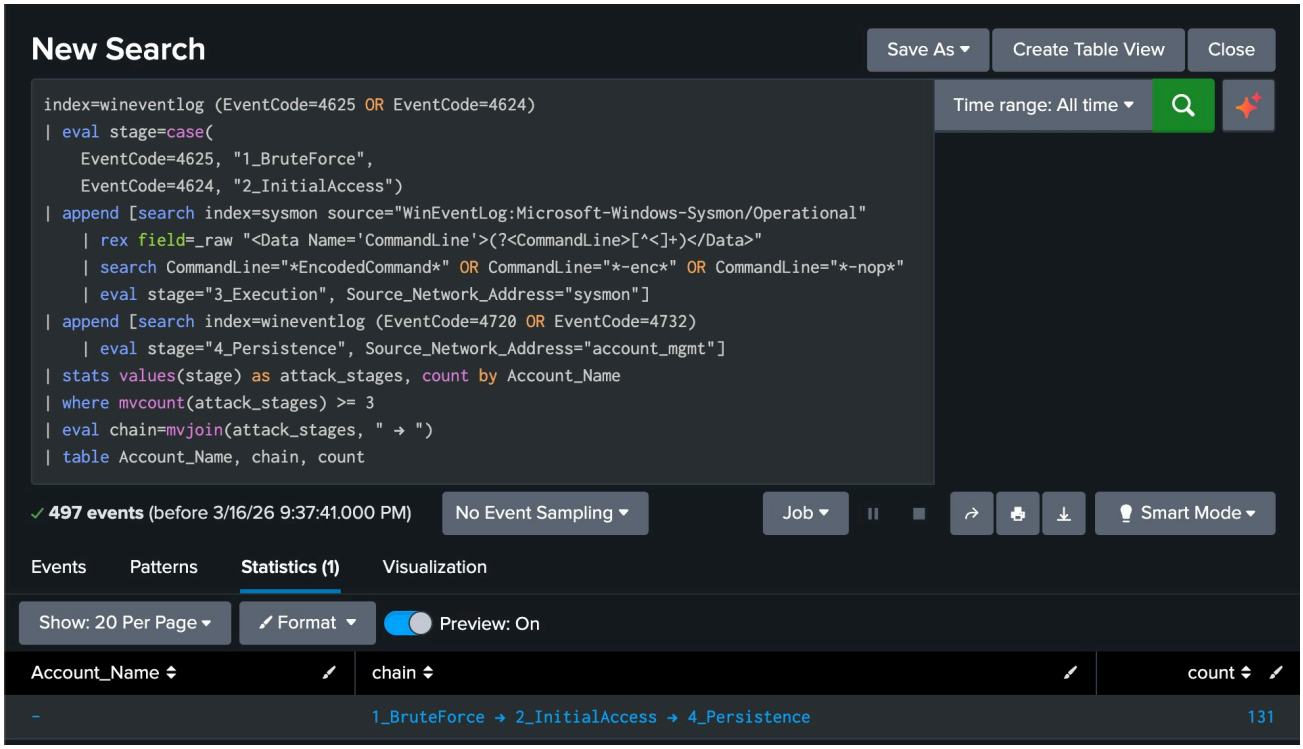

Figure 10: Rule 5 - Multi-stage attack chain detected: 1_BruteForce → 2_InitialAccess → 4_Persistence across 131 correlated events

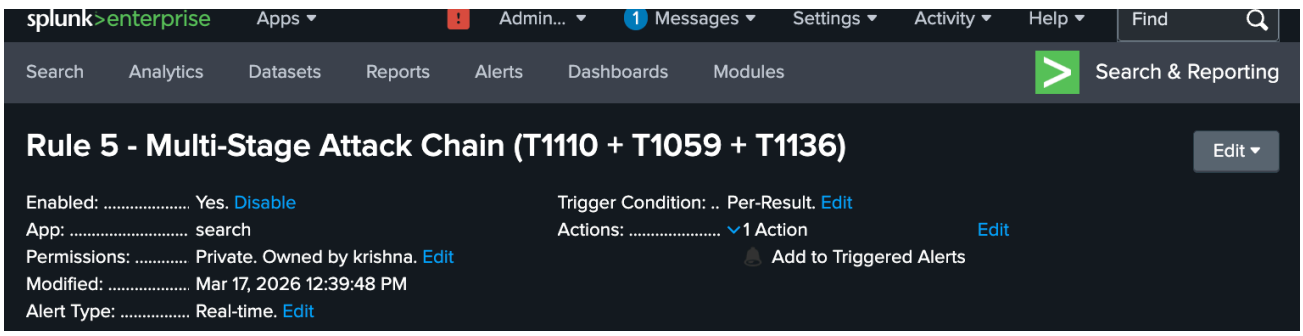

Figure 11: Rule 5 saved as a Real-time Splunk Alert

Stage 4: Monitor and Test Security

In this stage, all four detection rules were validated through controlled attack simulations executed from the Kali Linux VM. Each simulation was designed to generate the specific Windows Security and Sysmon event types targeted by the corresponding detection rule. All simulations were performed in an isolated lab environment - no real systems, credentials, or production networks were targeted.

Attack Simulation Procedure

- **Failed RDP Login Test:** A single failed RDP authentication attempt was generated from Kali Linux using xfreerdp with incorrect credentials to confirm that Event ID 4625 was captured in the wineventlog index.
- **Brute Force Simulation:** A shell loop script was used to send 20 consecutive failed RDP login attempts against the Windows VM administrator account, generating a burst of 4625 events sufficient to trigger Rule 1.
- **Successful Login After Failures:** Following the brute force loop, a successful RDP authentication was performed from Kali Linux using valid credentials, generating Event ID 4624 and triggering Rule 2.
- **Encoded PowerShell Simulation:** A Base64-encoded PowerShell command was executed on the Windows VM using the -EncodedCommand flag, captured by Sysmon as Event ID 1 with the full CommandLine argument, triggering Rule 3.
- **New Admin Account Creation:** Two commands were executed - net user hacker /add (Event ID 4720) and net localgroup Administrators hacker /add (Event ID 4732) - triggering Rule 4.
- **Multi-Stage Chain Validation:** Rule 5 was validated using the cumulative events from all prior simulations — brute force, successful access, and persistence events were correlated automatically, producing the attack chain 1_BruteForce → 2_InitialAccess → 4_Persistence.

```
┌──(kali㉿Kali)-[~]
└─$ xfreerdp /u:wronguser /p:wrongpass /v:192.168.64.10
[16:19:34:973] [9830:9833] [WARN][com.freerdp.crypto] - Certifi
ate verification failure 'self-signed certificate (18)' at stac
 position 0
[16:19:34:973] [9830:9833] [WARN][com.freerdp.crypto] - CN = DE
KTOP-Q5BGQL6
[16:19:34:176] [9830:9833] [WARN][com.freerdp.core.nla] - SPNEG
 received NTSTATUS: STATUS_LOGON_FAILURE [0×C000006D] from serv
r
[16:19:34:176] [9830:9833] [ERROR][com.freerdp.core] - nla_recv
pdu:freerdp_set_last_error_ex ERRCONNECT_LOGON_FAILURE [0×00020
14]
[16:19:34:176] [9830:9833] [ERROR][com.freerdp.core.rdp] - rdp_
ecv_callback: CONNECTION_STATE_NLA - nla_recv_pdu() fail
[16:19:34:176] [9830:9833] [ERROR][com.freerdp.core.transport]
 transport_check_fds: transport→ReceiveCallback() - -1
```

Figure 12: xfreerdp failed RDP login from Kali - ERRCONNECT_LOGON_FAILURE, generating Event ID 4625

```
┌──(kali㉿Kali)-[~]
└─$ for i in {1..10}; do   xfreerdp /u:administrator /p:wrongpass$i /v:192.168.64.10 +auth-only 2>/dev/null;   ec
ho "Attempt $i done"; done
[16:21:54:685] [13933:13934] [INFO][com.freerdp.client.x11] - Authentication only. Don't connect to X.
Attempt 1 done
[16:21:54:101] [13952:13953] [INFO][com.freerdp.client.x11] - Authentication only. Don't connect to X.
Attempt 2 done
[16:21:54:519] [13963:13964] [INFO][com.freerdp.client.x11] - Authentication only. Don't connect to X.
Attempt 3 done
[16:21:55:938] [13974:13975] [INFO][com.freerdp.client.x11] - Authentication only. Don't connect to X.
Attempt 4 done
[16:21:55:363] [13993:13994] [INFO][com.freerdp.client.x11] - Authentication only. Don't connect to X.
Attempt 5 done
[16:21:56:791] [14004:14005] [INFO][com.freerdp.client.x11] - Authentication only. Don't connect to X.
Attempt 6 done
[16:21:56:207] [14023:14024] [INFO][com.freerdp.client.x11] - Authentication only. Don't connect to X.
Attempt 7 done
[16:21:57:629] [14034:14035] [INFO][com.freerdp.client.x11] - Authentication only. Don't connect to X.
Attempt 8 done
[16:21:57:040] [14053:14054] [INFO][com.freerdp.client.x11] - Authentication only. Don't connect to X.
Attempt 9 done
[16:21:57:458] [14064:14065] [INFO][com.freerdp.client.x11] - Authentication only. Don't connect to X.
Attempt 10 done
```

Figure 13: 20-attempt brute force loop from Kali each attempt generating Event ID 4625

```
C:\Windows\System32>net user hacker P@ssword123! /add
The command completed successfully.


C:\Windows\System32>net localgroup Administrators hacker /add
The command completed successfully.
```

Figure 14: net user hacker /add and net localgroup Administrators hacker /add generating Event IDs 4720 and 4732

Validation Results

Detection Rule	Alert Fired	False Positives	Key Findings
Rule 1: Brute Force	Yes	None	44-50 failed logins per 5-min bucket from 192.168.64.2. Source_Network_Address is the correct SPL field name.
Rule 2: Login After Failure	Yes	None	117 failures + 1 success from Kali IP correlated correctly. eval + stats pattern used for status classification.
Rule 3: Encoded PowerShell	Yes	None	10 Sysmon EID 1 events with -EncodedCommand captured. Rex extraction required for XmlWinEventLog sourcetype.
Rule 4: New Admin Account	Yes	None	EID 4720 and 4732 for user hacker detected within seconds of execution. SubjectUserName confirmed creator identity.
Rule 5: Multi-Stage Chain	Yes	None	Attack chain 1_BruteForce → 2_InitialAccess → 4_Persistence detected across 131 correlated events.

SOC Dashboard

A 5-panel SOC dashboard titled Enterprise Threat Hunting SOC Dashboard was built in Splunk to provide real-time operational visibility across all detection scenarios. Panels include a line chart of failed logins over time, a bar chart of top attacking source IPs, a table of suspicious PowerShell executions with full CommandLine data, and a table of new admin account creation events.

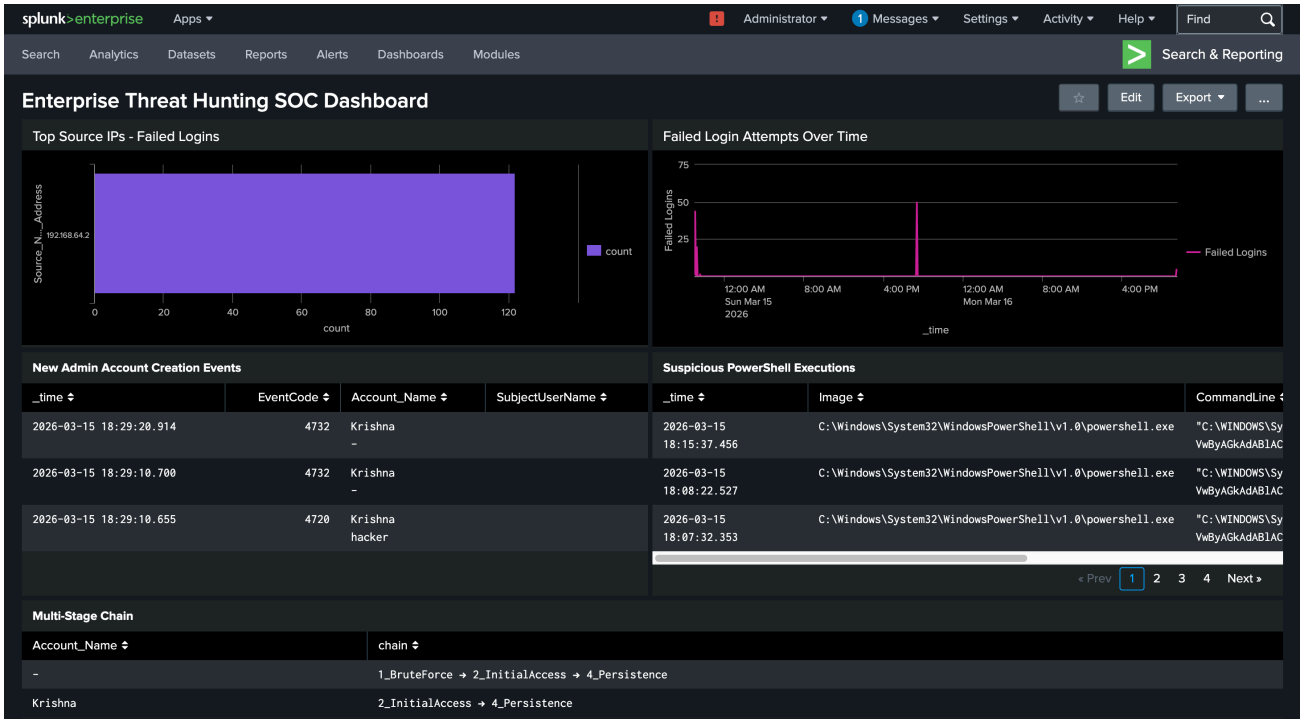

Figure 15: Enterprise Threat Hunting SOC Dashboard - all 5 panels populated with real attack simulation data

Stage 5: Review and Improve

In this final stage, the performance of all four detection rules was reviewed against the simulation results. Technical findings were documented and a continuous improvement roadmap was defined to extend the detection capability of the environment.

Observations and Lessons Learned

- **ARM64 Compatibility:** The standard Sysmon64.exe binary is x86_64 only and fails with errorCode=5 on ARM64 Windows. Sysmon64a.exe included in the same download package is the correct binary for Apple Silicon virtual machines running Windows 11 ARM64.
- **Forwarder Permissions:** The Splunk Universal Forwarder initially lacked permission to read the Sysmon event channel, causing errorCode=5. Resolved by changing the SplunkForwarder Windows service to run under the Local System account.
- **SPL Field Names:** Windows Event Log events use Source_Network_Address for the attacker IP, not src_ip. Inspecting the raw event was essential to identify the correct field name before writing detection rules.
- **XML Sourcetype Parsing:** Sysmon events use the XmlWinEventLog sourcetype and do not auto-extract fields like CommandLine or Image. Rex field=_raw commands were required to parse these from the XML before the PowerShell rule could function.
- **Account Lockout During Testing:** The Windows administrator account locked out during the Hydra brute-force test due to default lockout policy. Resolved by switching to a manual xfreerdp loop script and temporarily disabling the account lockout threshold.
- **Multi-Stage Correlation:** Rule 5 requires events from multiple indexes to share a common Account_Name field for correlation. Events where Account_Name is empty or '-' are grouped separately — this is expected behavior and does not affect rule accuracy.

Continuous Improvement Plan

- Integrate geo-IP enrichment using the Splunk iplocation command with MaxMind database to surface geographic anomalies in authentication alerts
- Expand lateral movement detection by correlating Event ID 4624 Type 3 (network logon) events across multiple hosts to identify east-west movement patterns
- Apply Splunk MLTK DensityFunction algorithm to establish login-time behavioral baselines and flag anomalous off-hours authentication activity
- Integrate AbuseIPDB threat intelligence via a custom Splunk lookup table to automatically flag known malicious IPs in brute-force alerts
- Extend PowerShell detection to cover additional obfuscation patterns including -WindowStyle Hidden, -NonInteractive, and concatenated string execution
- Configure automated Splunk Adaptive Response actions to disable flagged accounts upon Rule 4 triggering, reducing time from detection to containment
- Add network connection monitoring via Sysmon Event ID 3 to detect outbound connections to rare or suspicious external IPs

Work Done by Security Analyst

- Deployed and configured a complete home lab on Apple Silicon Mac using UTM with Windows 11 ARM64 and Kali Linux virtual machines
- Installed and validated Sysmon64a (ARM64 build) with the SwiftOnSecurity configuration for broad-coverage endpoint telemetry
- Configured Windows Audit Policies and verified all relevant Event IDs were generating correctly in the Security log
- Installed and configured the Splunk Universal Forwarder to ship Security, System, and Sysmon logs to Splunk Enterprise in real time
- Resolved ARM64-specific compatibility issues including Sysmon driver installation and Splunk Forwarder channel permissions
- Wrote and validated four SPL detection rules covering T1110.001, T1110, T1059.001, and T1136.001
- Executed controlled attack simulations from Kali Linux RDP brute-force loops, encoded PowerShell payloads, and admin account creation
- Confirmed all four detection rules fired correctly with zero false positives across all simulations
- Built a 5-panel SOC dashboard in Splunk providing real-time visibility across all detection scenarios
- Documented the full project lifecycle including threat hunting hypotheses, SPL queries, validation results, lessons learned, and improvement roadmap